

PRUEBA TÉCNICA · CIBERSEGURIDAD

Arquitectura de Seguridad

As-Is / To-Be · Modelo C4 · Flujo del pipeline

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

- 1. As-Is vs To-Be (postura de seguridad)**
- 2. Arquitectura objetivo (C4 Container + fronteras de confianza)**
- 3. Flujo de datos del incidente (brecha INC-2026-001)**
- 4. Pipeline DevSecOps (fan-out / fan-in, ≤ 15 min)**

Autora: Lady Marcela Romero Rivero · Líder de Ciberseguridad · Fecha: 2026-08-23 · Versión: 1.0
Todos los diagramas se renderizan de forma nativa en GitHub (Mermaid). Para el artefacto canónico en draw.io, importe el código Mermaid en draw.io: Arrange → Insert → Advanced → Mermaid.

1. As-Is vs To-Be (postura de seguridad)

Dominio	AS-IS (hoy, sin programa maduro)	TO-BE (línea base objetivo)
Identidad	Usuarios IAM, sin MFA, admin en cuentas de servicio	SSO + MFA, STS, rol por servicio, barreras de protección SCP
Borde	Sin WAF, puerto 80/443 directo	CloudFront + WAF v2 (SQLi/bad-inputs/rate/geo)
Red	Plana, RDS público, SG 0.0.0.0/0	VPC de 3 capas, subred de datos aislada, sin RDS público
Datos	AES-256 por defecto, BPA parcial	SSE-KMS CMC, BPA de cuenta, Object Lock en logs
Secretos	Codificados en el código fuente (V-10)	Secrets Manager, rotación de 30 días
Logging	Trail regional, sin validación, PII en logs	Trail multirregión + validación, enmascaramiento de PII
Detección	Ninguna	GuardDuty + Security Hub + reglas Sigma + threat-intel set
SDLC	Sin puertas de seguridad	Pipeline DevSecOps (SAST/SCA/DAST/IaC/secretos), ≤15 min
IR	Ad-hoc	Playbook NIST 800-61, mapeo MITRE, ruta a la SIC

2. Arquitectura objetivo (C4 Container + fronteras de confianza)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.

Fronteras de confianza: TB1 internet→borde (WAF), TB2 borde→app (SG-app solo desde el ALB), TB3→TB4 app→datos (SG-data 5432 solo desde SG-app; la subred de datos no tiene ruta a internet).

Clasificación de datos: RDS/S3 = **PII (Ley 1581)**; Secrets Manager = **secretos**; logs de CloudTrail = **auditoría/inmutable**.

3. Flujo de datos del incidente (brecha INC-2026-001)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.

4. Pipeline DevSecOps (fan-out / fan-in, ≤15 min)

Diagrama — versión navegable en el repositorio (Mermaid) y export draw.io/PNG.